

Questions

1. (10 points) Intercepting a login request with the credentials of “joe” and “pass” displays the following URL: *http://www.wahh-app.com/app?action=login&uname=joe&password=pass*

What **three** vulnerabilities can be diagnosed by simply looking at this URL?

The URL indicates that the query string contains the login credentials explicitly. The username and password can be stored in browser history, server logs, and proxy logs because *uname=joe&password=pass* is displayed in the URL, making it simple to steal or examine them at a later time. This puts the user at serious danger and is inadequate handling of sensitive data.

The login request is sent over the network in plain text since the connection uses HTTP rather than HTTPS. The credentials can be obtained and used to impersonate the user by anyone intercepting the traffic, including an attacker on the same Wi-Fi network. A major weakness in any authentication procedure is the absence of encryption.

The login process uses a GET request rather than a POST request, which is improper for managing credentials. The ease with which GET queries can be cached, recorded, and replayed raises the possibility of credential leakage or abuse. Using POST over HTTPS and completely missing users and passwords in the URL would be necessary for proper safe design.

2. (2.5 x 8 = 20 points) You log in to an application at the following URL:

https://app.news24hours.com/login/home.php

After successful authentication, the server sets the following cookie:

Set-cookie: sessionId=1498172056438227; domain=app.news24hours.com; path=/login; HttpOnly;

To which of the following URLs will the *sessionId* cookie be submitted? Explain why or why not.

- a) *https://app.news24hours.com*
- b) *https://app.news24hours.com/login/myaccount.php*
- c) *https://web.news24hours.com/login*
- d) *https://raw.app.news24hours.com/login/home.php*
- e) *http://app.news24hours.com/login/myaccount.php*
- f) *http://app.news24hours.com/logintest/login.php*
- g) *https://app.news24hours.com/logout*
- h) *https://testapp.news24hours.com/login/myaccount.php*

Note: The *HttpOnly* flag does not determine whether cookies are transmitted via HTTP or HTTPS connections. It only specifies that cookies are not accessible via client-side scripts.

Number	Submitted Yes/ No	Explanation
a	No	Path / does not start with /login
b	Yes	Same domain, path starts with /login
c	No	Not app. subdomain
d	Yes	Includes subdomain and path
e	Yes	Includes subdomain and path, http allowed
f	Yes	/login matches path rules
g	No	Path /logout is not /login
h	No	Not app. subdomain